

安全漏洞审计报告 · 第8轮

用户信息管理平台 命令注入漏洞审计报告

User Management Platform — Command Injection Assessment

目标系统：用户信息管理平台 (Flask)

报告日期：2026-07-16

漏洞等级：严重 × 2

修复状态：✅ 全部已修复

目录

1. 报告概述
2. 漏洞详情
3. 攻击演示
4. 修复方案
5. 修复前后对照
6. 修复验证
7. 全部八轮汇总

1. 报告概述

1.1 本轮背景

系统新增了**Ping** 网络诊断功能（/ping），使用 `f"ping -c 3 {ip}"` 拼接命令并以 `shell=True` 执行。攻击者可在 IP 参数中添加 `;`、`|` 等分隔符执行任意系统命令，实现远程代码执行（RCE）。

1.2 什么是命令注入？

命令注入（**Command Injection**）攻击者将恶意命令注入到系统命令的参数中。当应用使用 `shell` 执行拼接后的字符串时，分隔符后的命令也会被执行。这是最危险的 Web 漏洞之一，可导致服务器完全被控。

2. 漏洞详情

2

● 严重漏洞

2/2

✓ 已修复

VULN-25 : Ping 命令注入 (RCE)

● 严重

位置 : /ping — POST 路由

漏洞代码 :

```
ip = request.form.get("ip", "")
cmd = f"ping -c 3 {ip}" ← f-string 拼接, 无过滤
subprocess.check_output(cmd, shell=True) ← shell=True 执行
```

描述 : IP 参数直接拼入命令, 攻击者可添加 ;cat /etc/passwd 等后缀执行任意命令。

VULN-26 : 远程代码执行

● 严重

描述 : 利用命令注入可执行 : id (查用户身份)、cat /etc/passwd (读系统文件)、ifconfig (看网络配置)、ls -la (看目录)

攻击场景 : 输入 8.8.8.8;cat /etc/shadow → ping 结束后执行 cat → 密码哈希泄露

3. 攻击演示

3.1 执行系统命令

📌 攻击请求

```
POST /ping ip=8.8.8.8;id
```

🧠 实际执行的系统命令

```
ping -c 3 8.8.8.8;id
```

结果

```
uid=0(root) ← root 权限!
```

3.2 读取敏感文件

📌 攻击请求

```
POST /ping ip=8.8.8.8;cat /etc/passwd
```

结果

```
root:x:0:0:root:/root:/usr/bin/zsh
```

```
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
```

✅ 系统用户列表泄露

3.3 其他恶意操作

📌 攻击 Payload 汇总

```
8.8.8.8;whoami → root
```

```
127.0.0.1;ls -la → 目录列表
```

```
8.8.8.8;ifconfig → 网络配置
```

```
8.8.8.8;cat /etc/shadow → 密码哈希
```

4. 修复方案

4.1 输入白名单校验

```
import re
if not re.match(r'^[a-zA-Z0-9.\-]+$' , ip):
    result = "包含非法字符，只允许 IP 地址或域名"
```

4.2 禁止 shell 执行

```
cmd = ["ping", "-c", "3", ip] # 参数列表
subprocess.check_output(cmd, shell=False) # 禁止 shell
```

5. 修复前后对照

✖ 修复前

```
f"ping -c 3 {ip}"  
shell=True
```

- 8.8.8.8;id ✔ 可执行
- 远程命令执行成功

✔ 修复后

```
regex 白名单校验  
["ping","-c","3",ip]  
shell=False
```

- 8.8.8.8;id ❌ 被拦截
- 攻击失败

6. 修复验证

#	测试	结果
1	8.8.8.8;id 命令注入 → 被拦截	✓ 通过
2	127.0.0.1 whoami 管道注入 → 被拦截	✓ 通过
3	正常 ping 8.8.8.8 → 正常运行	✓ 通过
4	域名 google.com → 正常运行	✓ 通过

7. 全部八轮汇总

轮次	审计内容	漏洞数	严重	高危	中危	状态
第 1 轮	密码安全	8	4	-	4	✓
第 2 轮	SQL 注入	2	2	-	-	✓
第 3 轮	文件上传	1	1	-	-	✓
第 4 轮	业务逻辑	7	2	2	3	✓
第 5 轮	文件包含	2	2	-	-	✓
第 6 轮	CSRF	2	1	1	-	✓
第 7 轮	SSRF	2	2	-	-	✓
第 8 轮	命令注入	2	2	-	-	✓
合计		26	16	3	7	全部已修复

安全漏洞审计报告 · 第8轮 — 命令注入安全 | 报告日期：2026-07-16

项目地址：<https://github.com/sencly-book/user-management>